

Economics & Risk Management



Nancy LaTourrette
Computer Science & Engineering

Cyber-Risk Oversight

Five principles of balancing cybersecurity with profitability:

1. Directors need to understand and approach cybersecurity as an **enterprise-wide risk management issue**, not just an IT issue. *everyone must pitch in to avoid user error holes*
2. Directors should understand the **legal implications of cyber risks** as they relate to their company's specific circumstances. *→ fines, lawsuits, etc*
3. Boards should have adequate access to cybersecurity expertise, and discussions about **cyber-risk management should be given regular and adequate time** on the board meeting agenda.

Cyber-Risk Oversight

4. Directors should set the expectation that management will **establish an enterprise-wide cyber-risk management framework** with adequate staffing and budget.
5. Board-management discussion of cyber risk should include identification of which risks to avoid, accept, mitigate, or transfer through insurance, as well as **specific plans associated with each approach.**

over-plan w/ scenarios

-- *Cyber-Risk Oversight, 2014 Edition*

National Association of Corporate Directors

Losses Due to Cybersecurity Breaches

Global Averages



Average size of
a data breach

25,575 records

Average total cost of a data breach

~~\$3.92M~~

Cost per
lost record

~~\$150~~

Time to identify and
contain a breach

~~279 days~~

Highest country average
cost of ~~\$8.29~~ million

United States

Highest industry average
cost of ~~\$6.45~~ million

Healthcare ~~\$7.48~~

~~\$4.35M~~

~~\$9.44M~~

~~\$10.10M~~

\$4.44

\$10.22M

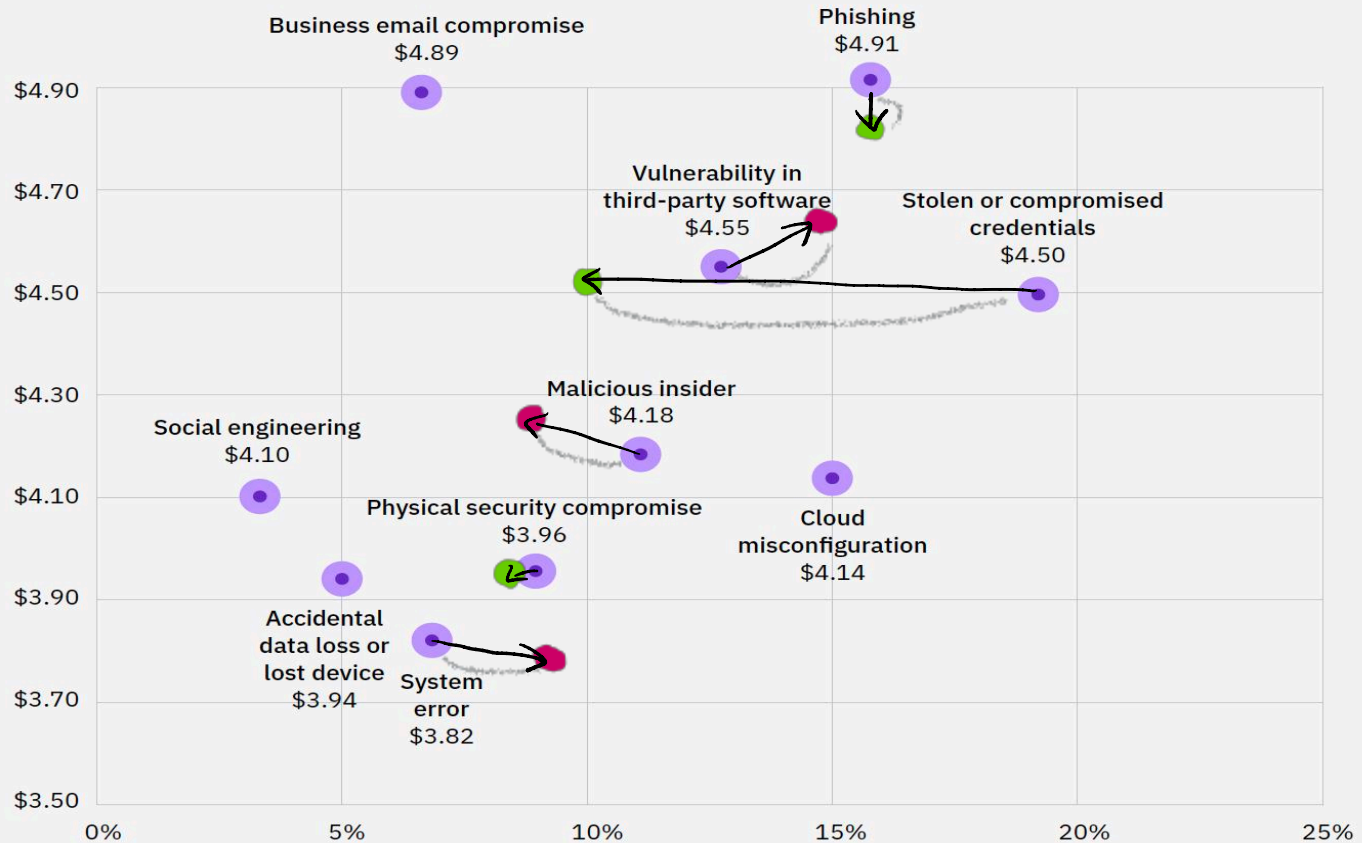
-- IBM Security - Cost of a Data Breach Report 2019

+ 2022

+ 2025

Costs and Frequency by Attack Vector

Average cost and frequency of data breaches by initial attack vector



-- IBM Security – Cost of a Data Breach Report 2022

Economic Losses

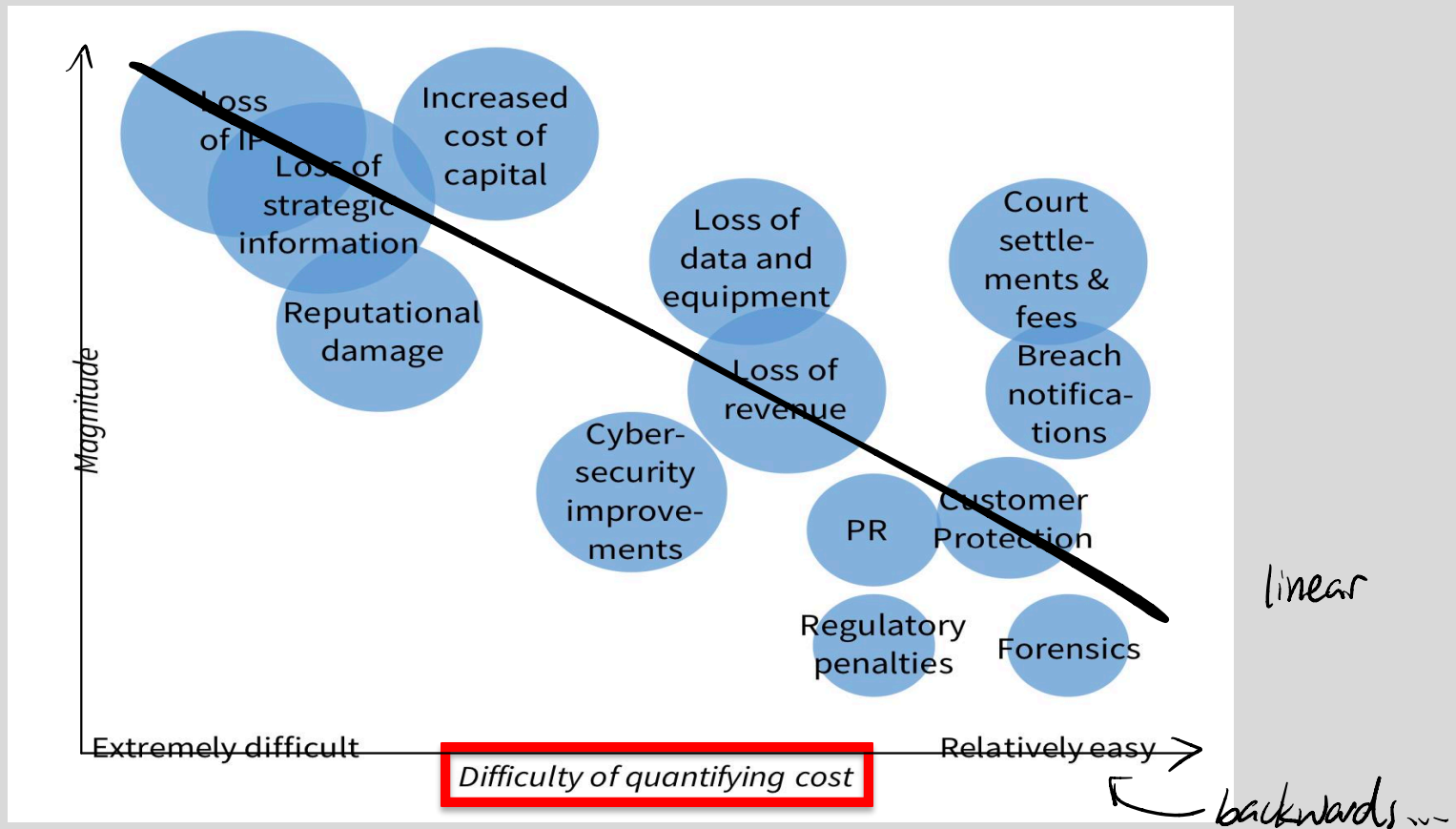
- *Direct costs:*

Theft of financial assets, lost revenues during outages, loss of sensitive business information, cost of recovery, compensation to victims, deferred investments.

- *Indirect costs:*

Reputational damage, loss of confidence in cyber transactions, lower returns on innovation.

Cost Component of Cyber Breach



- *The Cost of Malicious Cyber Activity to the U.S. Economy*, Council of Economic Advisors 2018

Longtail Cost of Cyber Breach



67% of costs occur in the first year



22% of costs occur in the second year



11% of costs occur after two years

-- IBM Security – Cost of a Data Breach Report 2019

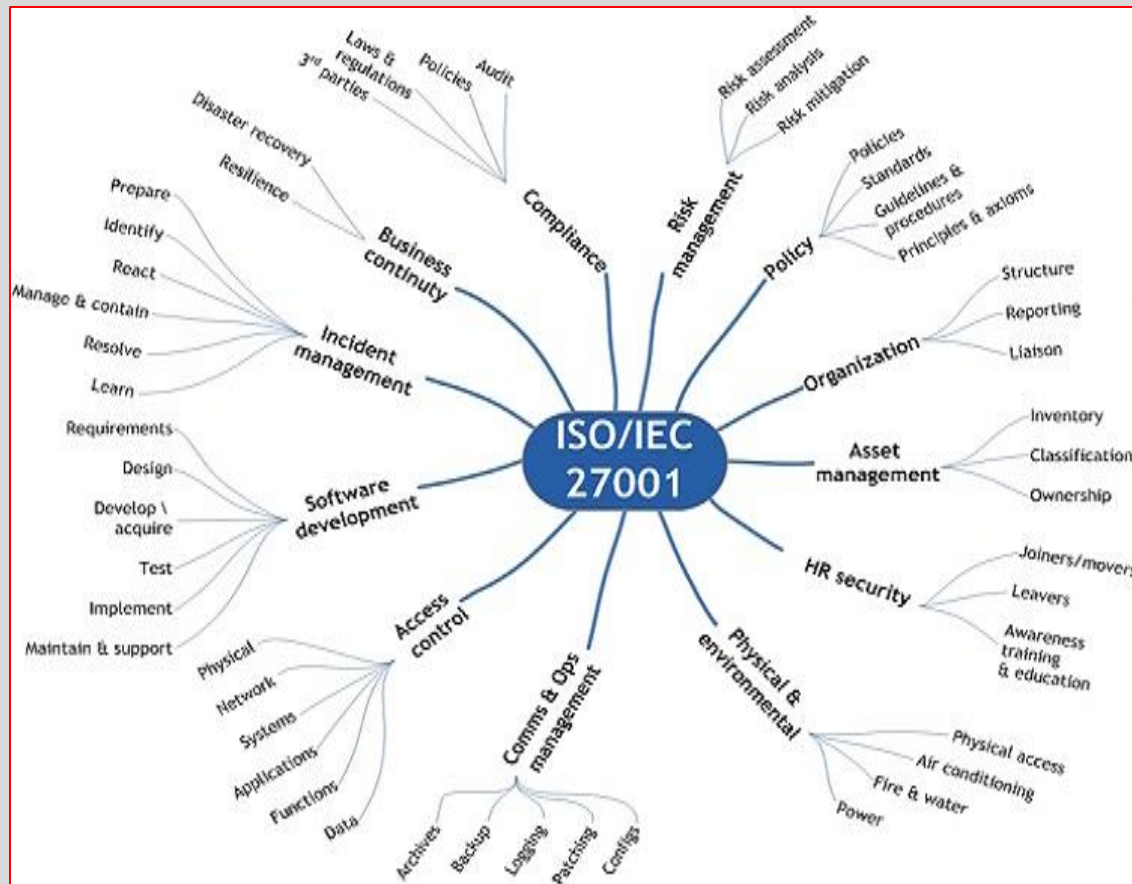
Asymmetric Costs

Asymmetric costs of defense vs. offense:

- Attacking is **easy and cheap**.
- Defending is **extremely expensive**, with perfect security unachievable.
- According to Ponemon Institute, “real-world cost of an unmitigated attack is \$40,000 per hour,” while the price of launching certain kinds of attacks (DDOS) is about \$38 dollars per hour.

Cost of Compliance

Public and private attempts to establish cybersecurity standards entail a **significant *cost of compliance***:



Cybersecurity Risk Management

Risk is the extent to which an entity is threatened by a potential adverse event.

Risk Dependencies: (1) **Negative impacts** that arise if the adverse event occurs, and (2) **Likelihood of occurrence** of the adverse event. *aka what bad could happen, and how likely in that situation*

Risk Management: Process of **identifying and controlling** risks.

Risk Identification: Process of examining organization's **current security situation**.

Risk Control: Applying **controls to reduce risks**.

Risk Function

Risk = threat x vulnerability x asset ← *conceptual*

Asset: Any tangible or intangible thing or characteristic that has value to an organization.

Threat: Circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system [CNSSI 4009].

Vulnerability: Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source [CNSSI 4009].

Risk Assessment

*Risk assessment evaluates relative risk for each vulnerability and **assigns a risk rating or score to each information asset.***

Likelihood:

- The probability that a specific vulnerability will be the object of a successful attack.
- Assign numeric value: number between 0.1 (low) and 1.0 (high), or a number between 1 and 100.
- Zero not used since vulnerabilities with zero likelihood are removed from asset/vulnerability list.
- Use selected rating model consistently.
- Use external references for values that have been reviewed/adjusted for your circumstances.

Risk Determination:

- For the purpose of relative risk assessment risk equals:
- Likelihood of vulnerability occurrence TIMES value (or impact).
- MINUS percentage risk already controlled.
- PLUS an element of uncertainty.

$$\text{RISK} = (\text{LIKELIHOOD} \times \text{VALUE}) \\ - \text{ALREADY CONTROLLED} \\ + \text{UNCERTAINTY}$$

Risk Control Strategies

Once risk assessment is complete, choose (business continuity) strategy to control each risk:

Defend (Preferred Approach) - Attempt to **prevent exploitation** of the vulnerability.

Transfer - Control approach that attempts to **shift risk** to other assets, processes or organizations. ← 3rd parties equally risky

Mitigate - Attempt to **reduce impact** of through planning and preparation.

- Incident Response Plan
- Disaster Recovery Plan
- Business Continuity Plan

concrete plans allow for control and controlled disaster handling

Risk Control Strategies

Accept – Do not protect a vulnerability and accept the outcome of its exploitation.

Terminate – Avoid those business activities that introduce uncontrollable risks.

Risk Control Strategies

Risk control strategies from a technology standpoint:

Attack Prevention – Stop attacks before they can hit their target.

Attack Detection – Detect attacks as they occur.

Attack Source Identification – Locate the attack sources.

Attack Reaction – Eliminate or curtail the effects of an attack.

all 4 are necessary

Risk Control Characteristics

Important characteristics of risk control strategies:

Effective – Stops disruptive and degrading attacks. Successful against variants and does not “push problem upstream”.

Accurate – Attack traffic is dropped while legitimate traffic continues. **Low collateral damage.**

Reasonable Cost – Defense system is economical and relatively low cost, especially when no attack is occurring.

Deployable – Defense systems on or near to the potential target.

Complete – Ideal defense system should handle most types of attacks and **easily evolve.**

Risk Control Methodologies

Common risk control assessment and management methodologies:

- National Institute of Standards & Technology (NIST) Methodology
- ISO/IEC 27001/27002
- OCTAVE® - Operationally Critical, Threat, Asset and Vulnerability Evaluation
- FRAP - Facilitated Risk Assessment Process
- COBRA - Consultative, Objective and Bi-functional Risk Analysis
- COBIT - Control Objectives for IT

Acknowledgement

This material is based upon work supported by the National Science Foundation under Grant No. 1516724.

